atividade

uma instituição de ensino com data center e o equipamentos dos mais diversos, uma instituição como uma escola como a de fortaleza.

instituição de ensino
—----------
2.500 alunos
professores
funcionário administrativo
—----------
data center { onprimese
|
-> servidor de arquivo.

{site (hospedagem contratada)
{app

lab. de informática { 03 { 30 máquinas cada
parque de comp. {desktop
{notebook

é preciso fazer o plano de segurança da informação

nome: Caio César nascimento de oliveira
nome: andré luiz de souza lima barros

PLANO DE GESTÃO DE SEGURANÇA DA INFORMAÇÃO

Data	Versão	Descrição
03/11/2026	**1**	**elaboração do plano da segurança da informação**

Introdução

Um plano de segurança da informação é um documento estratégico que visa processos, políticas e procedimentos caso algo venha a ocorrer.

O arquivo tem como finalidade diminuir bastante as ameaças e vulnerabilidades, deste modo, é um documento essencial como em instituições de ensino.

A empresa analisada possui ativos como 3 salas de aula, cada uma com 30 máquinas cada.

O parque de computadores conta com (desktop e notebook), além de possuir data center onprimese é um servidor de arquivo, a instituição analisada conta com site e aplicativo.

Escopo:

O escopo deste documento busca descobrir e contemplar os riscos da segurança da informação e procurar medidas de segurança para proteger a privacidade e a segurança dos dados

OBJETIVOS:

O documento visa ajudar a instituição de ensino a ter um bom controle sobre seus ativos, sejam físicos como notebook e desktop ou até mesmo as salas ou digitais como os dados do usuário, deste modo, é uma boa pratica e ajuda a manter a

confidencialidade e integridade dos ativos.

Abrangência:

O plano desse projeto abrange medidas de informação, segurança da informação ,normas, procedimentos e ferramentas que busquem a privacidade e segurança dos dados

Plano de gestão de segurança da informação:

O plano de gestão de segurança da informação é composto por 12 (doze) etapas iterativas e incrementais. Estas etapas são compostas por diversas camadas uma incrementando a outra:
1 - monitoramento de ameaças e vulnerabilidades, 2 - desenvolvimento de políticas, programas, normas,processos, 3 - planos, contratos e procedimentos,
4 - treinamento e conscientização,5 - implementação de controles técnicos,
6 - monitoramento e detecção de incidentes, 7 - privacidade de dados,
8 - gestão de fornecedores e terceiros, 9 - gestão da segurança da rede,
10 - auditorias e revisões,11- conformidade regulatória, resposta a incidentes e
12 - melhoria contínua. A figura 6 apresenta de forma resumida as etapas que são utilizadas pelo IFTO para gerir a segurança da informação.

Os 12 pontos do plano de segurança da informação

1. Monitoramento de ameaças e vulnerabilidades

Essa etapa consiste em identificar possíveis ameaças e falhas que possam comprometer os sistemas e equipamentos da instituição.

Exemplo na nossa instituição:

Identificar computadores com vírus.

Verificar se os servidores possuem falhas de segurança.

Identificar senhas fracas.

Procurar programas desatualizados.

Identificar tentativas de invasão no aplicativo.

2. Desenvolvimento de políticas, programas, normas, processos, planos e contratos

Essa etapa é responsável por estabelecer políticas, programas, normas, processos, planos e contratos que visam o controle de acesso , gestão de arquivos, gestão de logs e vulnerabilidades do sistema

3. Planos, contratos e procedimentos

Essa etapa define o que deve ser feito quando ocorrer algum problema e quais responsabilidades cada pessoa ou empresa possui.

Exemplo:

Criar um plano de recuperação caso o servidor pare de funcionar.

Estabelecer contratos com empresas responsáveis pela hospedagem do site.

Definir procedimentos para recuperar arquivos apagados.

Criar um plano de continuidade das atividades caso ocorra um desastre.

Essa etapa prepara a instituição para situações inesperadas, estabelecendo procedimentos para resolver problemas e contratos que definem as responsabilidades dos fornecedores

4. Treinamento e conscientização

Não adianta ter equipamentos seguros se as pessoas não sabem utilizá-los corretamente.

Essa etapa ensina alunos, professores e funcionários a reconhecer riscos e evitar comportamentos perigosos.

Exemplo:

Ensinar a identificar e-mails falsos (phishing).

Orientar sobre senhas fortes.

Ensinar a não conectar pendrives desconhecidos.

Treinar funcionários para agir em caso de incêndio.

Orientar sobre o uso adequado do aplicativo institucional.

Essa etapa busca preparar as pessoas para evitar ameaças. Os usuários precisam saber reconhecer golpes, proteger suas senhas e agir corretamente diante de situações de risco.

5. Implementação de controles técnicos

Aqui entram as ferramentas tecnológicas utilizadas para proteger os equipamentos, sistemas e informações.

Exemplo:

Instalar antivírus nos computadores dos laboratórios.

Utilizar firewall para bloquear acessos perigosos.

Implementar autenticação de dois fatores (MFA) para gestores.

Utilizar criptografia para proteger informações.

Criar backups dos arquivos importantes.

Essa etapa consiste em colocar em prática soluções tecnológicas para proteger os ativos da instituição, dificultando invasões, roubos de informações e acessos não autorizados.

6. Monitoramento e detecção de incidentes

Enquanto o primeiro ponto procura ameaças e vulnerabilidades, este acompanha os sistemas para identificar quando um incidente está acontecendo ou já aconteceu.

Exemplo:

Detectar várias tentativas de login com senha incorreta.

Identificar um acesso suspeito ao servidor.

Perceber quando um computador começa a enviar dados indevidamente.

Identificar uma possível infecção por ransomware.

Registrar os horários e as atividades suspeitas.

Essa etapa monitora continuamente os sistemas da instituição para detectar atividades suspeitas e incidentes de segurança, permitindo que a equipe responsável tome providências rapidamente.

7. Privacidade de dados

Essa etapa busca proteger as informações pessoais dos alunos, professores e funcionários.

É importante lembrar que a instituição trabalha com dados que não devem ser acessados por qualquer pessoa.

Essa etapa protege os dados pessoais de todos que fazem parte da instituição, garantindo que as informações sejam utilizadas de maneira adequada e que somente pessoas autorizadas tenham acesso a elas.

8. Gestão de fornecedores e terceiros

A instituição não trabalha necessariamente sozinha. Ela pode contratar empresas externas para fornecer serviços tecnológicos.

Por isso, é necessário controlar quem são esses fornecedores e como eles lidam com as informações da instituição.

Exemplo:

Avaliar a segurança da empresa que hospeda o site.

Verificar a confiabilidade da empresa que mantém o aplicativo.

Exigir proteção dos dados nos contratos.

Controlar o acesso de técnicos terceirizados ao servidor.

Verificar se os fornecedores cumprem as exigências da LGPD.

Essa etapa serve para garantir que as empresas terceirizadas também sigam regras de segurança, evitando que um fornecedor se torne uma porta de entrada para ataques ou vazamentos de informações.

9. Gestão da segurança da rede

Essa etapa protege a rede de computadores utilizada pela instituição, incluindo conexões internas, internet, servidores e equipamentos.

Exemplo:

Criar redes separadas para alunos e funcionários.

Proteger o Wi-Fi com senhas fortes.

Configurar roteadores e switches corretamente.

Impedir que alunos acessem diretamente o servidor administrativo.

Utilizar firewall para controlar o tráfego da rede.

Essa etapa busca proteger toda a infraestrutura de comunicação da instituição, controlando os acessos à rede e impedindo que usuários não autorizados alcancem sistemas e informações restritas.

10. Auditorias e revisões

Aqui a instituição verifica se as regras e medidas de segurança estão realmente funcionando.

Não basta criar políticas: é necessário verificar se elas estão sendo cumpridas.

Exemplo:

Conferir se os funcionários possuem somente as permissões necessárias.

Verificar se os backups estão funcionando.

Avaliar se os computadores estão atualizados.

Conferir os registros de acesso ao servidor.

Identificar falhas nas políticas de segurança.

Essa etapa consiste em avaliar periodicamente os controles e procedimentos de segurança para verificar se estão funcionando corretamente e identificar o que precisa ser corrigido.

11. Conformidade regulatória e resposta a incidentes

Essa etapa possui duas responsabilidades importantes: garantir que a instituição cumpra as leis e estabelecer como agir quando ocorrer um incidente de segurança.

Exemplo de conformidade regulatória:

Cumprir a LGPD.

Proteger os dados pessoais dos alunos.

Respeitar as regras de armazenamento e utilização de informações.

Exemplo de resposta a incidentes:

Se ocorrer um vazamento de dados, investigar o ocorrido.

Se um computador for infectado, isolá-lo da rede.

Se o servidor parar, iniciar o plano de recuperação.

Identificar a origem do problema e tomar medidas para evitar que aconteça novamente.

Essa etapa garante que a instituição esteja de acordo com as leis e normas de segurança e também estabelece procedimentos para responder a incidentes, como invasões, vazamentos de dados e ataques virtuais.

12. Melhoria contínua

Essa é a etapa que busca melhorar constantemente todo o plano de segurança da informação.

A segurança não é algo que fazemos uma única vez. Novas ameaças aparecem, os sistemas mudam e as medidas de proteção precisam acompanhar essas mudanças.

Exemplo:

Atualizar os antivírus.

Melhorar as políticas de segurança.

Corrigir vulnerabilidades encontradas nas auditorias.

Atualizar os treinamentos dos funcionários.

Melhorar os procedimentos de recuperação de dados.

Essa etapa busca aperfeiçoar continuamente a segurança da instituição, utilizando os problemas encontrados, as auditorias e os novos riscos para melhorar as medidas de proteção.

Política de segurança da informação:

1 - objetivo:

Os ativos que devem ser protegidos são os bens materiais que a instituição possui além dos dados que são de grande valia hoje em dia, o qual não deve ser negligenciado nem excluído de forma deliberada, pois possui até leis para eles como da lgpd.

2 - Definir papeis de usuário:

Os alunos terão acesso ao mínimo necessário, podendo acessar somente as rotinas de praxe, como ver notas e seu nome e situações do aplicativo.

Enquanto os gestores terão permissões mais elevadas como corrigir algo ou inserir, deste modo, eles tem uma grande responsabilidade e devem ter MFA na conta.

3 - Regras:

Os gestores ficam responsáveis por a administração do aplicativo enquanto os alunos não tem tantas permissões , a sala deve ser trancada onde possui o servidor e só poderá ser aberta via biometria do usuário de mais alta patente, deve haver extintores de incendio no predio e brigadistas caso uma ameaça como fogo venha atentar contra a instituição.

deve ter um pára raios caso caia um relâmpago perto da instituição e não queime os ativos físicos

Os equipamentos devem constar com firewall físico e digital.

4 - aplicação:

deve haver alunos treinados assim como profissionais treinados caso ocorra alguma ameaça, treinamentos como saída na hora de incêndio